

SECURITY ASSESSMENT FINDINGS REPORT

TARGET › hexacoreclasses.in
Web Application Penetration Testing Report

DATE	PENTESTER	ORGANIZATION	CLASSIFICATION
22 / 04 / 2026	Prasad Sarkate	Future Interns	CONFIDENTIAL

EXECUTIVE CLASSIFICATION
This document contains sensitive security findings intended solely for authorized personnel. Unauthorized distribution is strictly prohibited.

Table of Contents

01 Confidentiality & Disclaimer	3
02 Assessment Overview & Methodology	4
03 Severity Rating Framework	5
04 Executive Summary	6
05 Finding 1 — Port & Service Enumeration	7
06 Finding 2 — Missing HTTP Security Headers	8
07 Finding 3 — Clickjacking Vulnerability	9
08 Finding 4 — Content Security Policy (CSP) Absent	10
09 Conclusion & Remediation Roadmap	11

This report was generated following an authorized penetration test engagement conducted between April 20–22, 2026. All findings are evidence-based.

01 Confidentiality & Disclaimer

Confidentiality Notice

This report is classified CONFIDENTIAL and is intended exclusively for authorized personnel of the commissioning organization. The contents must not be disclosed, copied, reproduced, or distributed to any third party without explicit written consent from the authorized stakeholder.

Authorized Scope

All testing activities were conducted solely on the domain hexacoreclasses.in, within the boundaries and timeframe agreed upon prior to engagement. No systems, networks, or applications outside this defined scope were accessed or assessed.

Legal Authorization

This penetration test was performed under full legal authorization from the target organization. The assessor assumes no liability for any actions taken based on the findings contained herein. Any misuse of this report's contents is the sole responsibility of the recipient.

Disclaimer

Security assessments are point-in-time evaluations. The findings represent the security posture of the target application at the time of testing. The introduction of new code, dependencies, or configurations after the assessment date may alter the risk profile. Annual reassessment is strongly recommended.

IMPORTANT NOTICE

This document must be stored securely and accessed only on a need-to-know basis. Printed copies must be destroyed after use via cross-cut shredding.

02 Assessment Overview & Methodology

The engagement followed a structured four-phase penetration testing methodology aligned with OWASP Testing Guide v4 and the Penetration Testing Execution Standard (PTES). Below is a summary of each phase and the tools deployed.

#	Phase	Activities	Tools Used
1	Planning & Scoping	Define rules of engagement, scope, objectives, and legal agreement	Scoping Document
2	Reconnaissance	Passive/active recon — DNS lookups, port scanning, header inspection	Nmap 7.98, Browser DevTools
3	Vulnerability Analysis	Automated scanning, spider crawling, alert triage, manual validation	OWASP ZAP 2.17.0, AJAX Spider
4	Reporting	Document findings, assign severity, provide evidence & remediation	ZAP Report, This Document

Target Application Overview

hexacoreclasses.in is an online education platform offering courses in programming, ethical hacking, and professional skills. The application is a Next.js-based modern web application hosted behind Cloudflare CDN, using dynamic content delivery and multiple third-party integrations.

The screenshot shows the OWASP ZAP (Zed Attack Proxy) interface. The top pane displays the HTTP response body for a request to `https://a.ne1.cloudflare.com/report/v4?...`. The response is an HTML document with a `Content-Type: text/html; charset=utf-8` and a `Cache-Control: max-age=3600`. The body contains a script that loads a file from `/_next/static/chunks/eb51b34e0a4e79ae.js`. The bottom pane shows a list of alerts, with `Modern Web Application (Systemic)` selected. The alert details pane on the right provides information about the application, including its URL, risk level, and a description.

Header: Text

HTTP/1.1 200 OK
Date: Sat, 02 May 2026 01:13:33 GMT
Content-Type: text/html; charset=utf-8
Connection: keep-alive
Cache-Control: max-age=3600
Report-To: {"group":"cf-nel","max_age":604800,"endpoints":[{"url":"https://a.ne1.cloudflare.com/report/v4?s=FICa%2B5nS4bsQ1FQgD522nVQj%2F%2Bz6NB9Z6%2BXu8Hjb4ph9dYoV9HfCcAdFfwQVxtP30ZUXJje2%2FVYvYtd7IybTxDn%2FzgaV6oI8kum0oi4DVrtP7cDz1ESrqa5PISin5Pat0%3D"}]}
Speculation-Rules: "/cdn-cgi/speculation"
last-modified: Sun, 22 Mar 2026 08:22:18 GMT
strict-transport-security: max-age=31556926

Body: Text

`<script src="/_next/static/chunks/eb51b34e0a4e79ae.js">`
`programming, ethical hacking, and professional skills with industry experts."`
`absolute";a.style.top=0;a.style.left=0;a.style.border='none';a.style.visibility='hidden';document.body.appendChild(a);if('load`

Alerts (12)

- Content Security Policy (CSP) Header Not Set (Systemic)
- Cross-Domain Misconfiguration
- Missing Anti-clickjacking Header (Systemic)
- Sub Resource Integrity Attribute Missing (Systemic)
- Cookie with SameSite Attribute None (Systemic)
- Strict-Transport-Security Header Not Set (Systemic)
- Timestamp Disclosure - Unix (Systemic)
- X-Content-Type-Options Header Missing (Systemic)
- Modern Web Application (Systemic)**
- Re-examine Cache-control Directives (Systemic)
- Retrieved from Cache (Systemic)
- Session Management Response Identified (16)

Modern Web Application

URL: `https://hexacoreclasses.in/courses/bca-semester-1-full-course-notes-8c31fcc7-5d2a-4e3e-a9f8-114259d48ba0`
Risk: Informational
Confidence: Medium
Parameter:
Attack:
Evidence: `<script src="/_next/static/chunks/4250ba24c2f9a555.js" async=""></script>`
CWE ID:
WASC ID:
Source: Passive (10109 - Modern Web Application)
Input Vector:
Description:
The application appears to be a modern web application. If you need to explore it automatically then the Ajax Spider may well be more effective than the standard one.

Figure 1 — Target application: hexacoreclasses.in (Full_Page_short.png)

03 Severity Rating Framework

All discovered vulnerabilities are classified using the Common Vulnerability Scoring System (CVSS v3.1) combined with business impact analysis. The table below defines the four severity tiers used throughout this report.

Severity	CVSS Score	Business Impact	Findings Count
CRITICAL	9.0 – 10.0	Full system compromise, data breach, service disruption. Immediate exploitation likely.	0
HIGH	7.0 – 8.9	Significant data exposure or system compromise. Exploitable with moderate skill or effort.	0
MEDIUM	4.0 – 6.9	Exploitable under specific conditions. Could lead to data leakage or privilege escalation.	3
LOW	0.1 – 3.9	Minimal risk. Informational or best-practice violations with limited direct exploitation potential.	1

✓ OVERALL RISK LEVEL: MEDIUM No critical or high-severity vulnerabilities were identified. The application presents a manageable risk profile with targeted remediation.	i ASSESSMENT SCOPE Passive reconnaissance, automated scanning, HTTP header analysis, and service enumeration. No exploitation attempts were made.
---	--

04 Executive Summary

A comprehensive web application security assessment was performed on hexacoreclasses.in between April 20–22, 2026. The assessment encompassed passive reconnaissance, active network port scanning, automated vulnerability scanning, and manual HTTP security header analysis.

The application leverages Cloudflare CDN for DDoS protection and traffic routing, which provides a meaningful baseline defense layer. However, several medium-priority security misconfigurations were identified that could be leveraged by a motivated attacker to conduct cross-site scripting, clickjacking, or session-based attacks.

Findings at a Glance

Vulnerability	Severity	CVSS	Status
Missing HTTP Security Headers (HSTS, X-Content-Type, X-Frame)	MEDIUM	4.3	Open
Content Security Policy (CSP) Not Configured	MEDIUM	4.3	Open
Clickjacking — Anti-clickjacking Header Absent	MEDIUM	4.3	Open
Port 8080 Exposed — Service Disclosure via Nmap	LOW	3.1	Open

Tools & Techniques Summary

Tool	Purpose	Phase	Findings
Nmap 7.98	Port / Service Scan	Reconnaissance	1 Low
OWASP ZAP 2.17.0	Automated Web Scan	Vulnerability Analysis	3 Medium
Browser DevTools	Header Inspection	Manual Analysis	1 Medium
AJAX Spider	Dynamic Content Crawl	Discovery	Informational

Finding 01 — Port & Service Enumeration

LOW SEVERITY

Severity	LOW (CVSS 3.1 Score: 3.1)
Confidence	High
Tool Used	Nmap 7.98 (Flag: -sV)
Target IP	172.67.163.37 (Cloudflare Proxy)
Open Ports	80/tcp (HTTP), 443/tcp (SSL), 8080/tcp (HTTP)
CWE	CWE-200 — Exposure of Sensitive Information

Description

Nmap service version detection identified three open TCP ports on the target host. Ports 80 and 443 are expected for a web application; however, port 8080 is additionally exposed and routes through the Cloudflare HTTP proxy. This may indicate a secondary application instance, reverse proxy, or staging environment running on a non-standard port.

Technical Risk

- ▶ Port 8080 exposure may allow bypassing certain WAF or firewall policies
- ▶ Service fingerprinting reveals Cloudflare routing, aiding attacker reconnaissance
- ▶ Additional ports increase the overall attack surface of the application

Remediation Steps

- ▶ Restrict port 8080 access via firewall rules to trusted IP ranges only
- ▶ Conduct quarterly port audits to detect and close unauthorized open ports
- ▶ Ensure Cloudflare firewall rules are configured to filter port-specific traffic

Evidence


```
(prasad@DESKTOP-I0T17QQ)~$ nmap -sV hexacoreclasses.in
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-02 06:23 +0530
Nmap scan report for hexacoreclasses.in (172.67.163.37)
Host is up (0.100s latency).
Other addresses for hexacoreclasses.in (not scanned): 104.21.15.168 2606:4700:3034::6815:fa8 2606:4700:3030::ac43:a325
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
80/tcp    open  http         Cloudflare http proxy
443/tcp   open  ssl/tcprawped
8080/tcp  open  http         Cloudflare http proxy

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 27.42 seconds

(prasad@DESKTOP-I0T17QQ)~$
```

Figure 2 — Nmap -sV scan output for hexacoreclasses.in (Namp_Scan_Result_1.png)

Finding 02 — Missing HTTP Security Headers

🚩 MEDIUM SEVERITY

Severity	MEDIUM (CVSS 3.1 Score: 4.3)
Confidence	High
Tool Used	Browser Developer Tools / OWASP ZAP
Affected URL	https://hexacoreclasses.in/
Missing Headers	Strict-Transport-Security, X-Content-Type-Options, X-Frame-Options
CWE	CWE-16 — Configuration / CWE-693 — Protection Mechanism Failure

Description

Analysis of the HTTP response headers revealed three critical browser security headers are absent from all server responses. These headers are a first line of defense that instruct browsers to enforce security policies on the client side. Their absence significantly weakens the application's resilience against a range of common web attacks.

Technical Risk per Header

- ▶ HSTS absent → Allows protocol downgrade attacks from HTTPS to HTTP (MITM risk)
- ▶ X-Content-Type-Options absent → Enables MIME-type sniffing, facilitating content injection
- ▶ X-Frame-Options absent → Application can be embedded in iframes (clickjacking vector)

Remediation Steps

- ▶ Add: Strict-Transport-Security: max-age=31536000; includeSubDomains; preload
- ▶ Add: X-Content-Type-Options: nosniff
- ▶ Add: X-Frame-Options: DENY (or SAMEORIGIN if framing is required internally)
- ▶ Validate headers post-deployment using securityheaders.com or ZAP rescan

Evidence

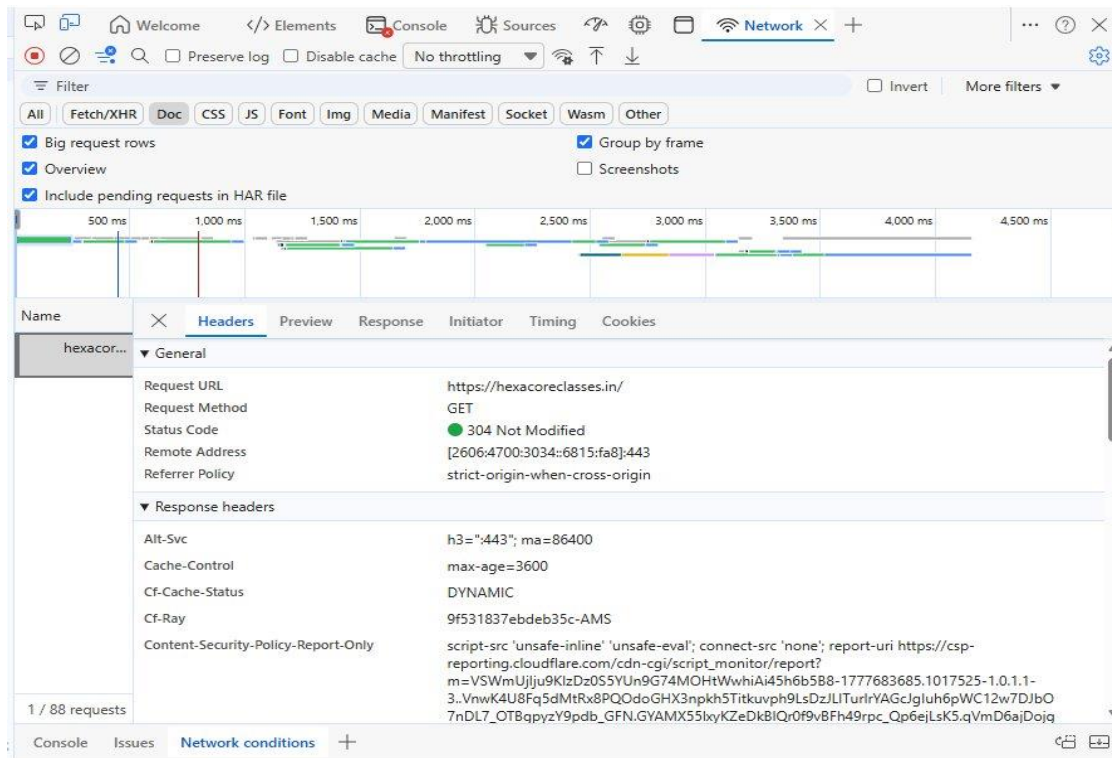


Figure 3 — Browser Developer Tools showing missing response headers (Dev_Tool_Report_1.png)

Finding 03 — Clickjacking Vulnerability**■ MEDIUM SEVERITY**

Severity	MEDIUM (CVSS 3.1 Score: 4.3)
Confidence	Medium
Tool Used	OWASP ZAP 2.17.0 — Alert: Anti-clickjacking Header Missing
Affected URL	https://hexacoreclasses.in/ (and all sub-pages)
Attack Vector	Remote — Network
CWE	CWE-1021 — Improper Restriction of Rendered UI Layers

Description

The application does not implement the X-Frame-Options header or the Content-Security-Policy frame-ancestors directive. This absence makes the site susceptible to UI Redressing (Clickjacking) attacks, wherein a malicious actor embeds the target site within a hidden iframe on an attacker-controlled page. Users interacting with the visible overlay unknowingly perform actions on the hidden target site.

Attack Scenario

- ▶ Attacker hosts a malicious page that invisibly loads hexacoreclasses.in in an iframe
- ▶ User is tricked into clicking buttons that trigger authenticated actions on the real site
- ▶ Could result in unauthorized course enrollments, account changes, or data submission

Remediation Steps

- ▶ **Set: X-Frame-Options: DENY** in all HTTP response headers
- ▶ **Or use CSP: Content-Security-Policy: frame-ancestors 'none'**
- ▶ **Run ZAP rescan after implementation to confirm the alert is resolved**

Evidence

The screenshot shows the ZAP web interface. The top menu bar includes File, Edit, View, Analyse, Report, Tools, Import, Export, Online, and Help. The main window is divided into several panes. The left pane shows 'Contexts' and 'Sites'. The top right pane displays the 'Header: Text' and 'Body: Text' of an HTTP response. The response header includes 'HTTP/1.1 200 OK', 'Date: Sat, 02 May 2026 01:13:33 GMT', 'Content-Type: text/html; charset=utf-8', 'Connection: keep-alive', 'Cache-Control: max-age=3600', 'Report-To: {\"group\": \"cf-nel\", \"max_age\": 604800, \"endpoints\": [{\"url\": \"https://a.nel.cloudflare.com/report/v4?s=FIca%2Bys4bsQ1fQgD522nVQjrn%2Fxu%2BRz6NB9Z6%2BXu8Hjb4ph9dYoV9MfCcAdFwQVsxtp30ZUXJje2%2FvYwYtd71yb1x0n%2FzgaV6oi8kum8oi14DvRtp7cDziE5rqae5P1SinsPat8%3D\"}]}\", 'Speculation-Rules: \"/cdn-gi/speculation', 'last-modified: Sun, 22 Mar 2026 08:22:18 GMT', and 'strict-transport-security: max-age=31556926'. The response body contains a script tag with a 'data-precendence' attribute and a 'link' attribute, which is highlighted in red. The bottom pane shows a table of 'Sent Messages' with columns for ID, Req. Timestamp, Resp. Timestamp, Method, URL, Code, Reason, RTT, Size Resp. Header, and Size Resp. Body. The table lists 10 messages, all with a status of 200 OK. At the bottom, there is a status bar with 'Alerts' and 'Current Status' indicators.

ID	Req. Timestamp	Resp. Timestamp	Method	URL	Code	Reason	RTT	Size Resp. Header	Size Resp. Body
37,995	5/2/26, 7:10:41 AM	5/2/26, 7:10:42 AM	GET	https://hexacoreclasses.in/images/team/51712941...	200	OK	1.11 s	886 bytes	17,867 bytes
37,996	5/2/26, 7:10:42 AM	5/2/26, 7:10:43 AM	GET	https://hexacoreclasses.in/images/team/15556398...	200	OK	1.27 s	887 bytes	17,867 bytes
37,998	5/2/26, 7:10:43 AM	5/2/26, 7:10:44 AM	GET	https://hexacoreclasses.in/leaderboard/144417625...	200	OK	953 ms	894 bytes	17,867 bytes
37,999	5/2/26, 7:10:44 AM	5/2/26, 7:10:46 AM	GET	https://hexacoreclasses.in/leaderboard/725194517...	200	OK	1.18 s	888 bytes	17,867 bytes
38,001	5/2/26, 7:10:46 AM	5/2/26, 7:10:47 AM	GET	https://hexacoreclasses.in/library/90213656037690...	200	OK	1.15 s	888 bytes	17,867 bytes
38,002	5/2/26, 7:10:47 AM	5/2/26, 7:10:48 AM	GET	https://hexacoreclasses.in/library/90473239086485...	200	OK	933 ms	882 bytes	17,867 bytes
38,004	5/2/26, 7:10:48 AM	5/2/26, 7:10:49 AM	GET	https://hexacoreclasses.in/playlist/1872388645736...	200	OK	1.2 s	982 bytes	18,856 bytes
38,005	5/2/26, 7:10:49 AM	5/2/26, 7:10:50 AM	GET	https://hexacoreclasses.in/playlist/8116540652603...	200	OK	1.12 s	982 bytes	18,856 bytes
38,007	5/2/26, 7:10:50 AM	5/2/26, 7:10:51 AM	GET	https://hexacoreclasses.in/practice/156954009776...	200	OK	1.17 s	887 bytes	18,472 bytes

Figure 4 — ZAP alert: Anti-clickjacking header missing (Zap_Report_Short_2.png)

Finding 04 — Content Security Policy (CSP) Absent**■ MEDIUM SEVERITY**

Severity	MEDIUM (CVSS 3.1 Score: 4.3)
Confidence	High
Tool Used	OWASP ZAP 2.17.0 — Passive Scan Alert
Affected URL	https://hexacoreclasses.in/
Attack Vector	Remote — Network
CWE	CWE-693 — Protection Mechanism Failure

Description

The Content-Security-Policy (CSP) HTTP response header is entirely absent from server responses. CSP is a critical browser-enforced security mechanism that defines trusted sources for scripts, styles, fonts, images, and other resources. Without CSP, browsers cannot distinguish between legitimate and malicious resource loads, significantly elevating the risk of Cross-Site Scripting (XSS) attacks and data injection.

Potential Attack Vectors

- ▶ Stored XSS → Malicious script injected and executed in all visiting users' browsers
- ▶ Reflected XSS → Crafted URL parameters deliver and execute client-side payloads
- ▶ Data exfiltration → Injected scripts transmit session tokens or user data to attacker servers

Remediation Steps

- ▶ **Begin with CSP report-only mode to identify breakages before enforcing**
- ▶ **Implement: Content-Security-Policy: default-src 'self'; script-src 'self'; object-src 'none'**
- ▶ **Eliminate all inline scripts and event handlers; use external JS files only**
- ▶ **Monitor via: Content-Security-Policy-Report-Only with a reporting endpoint**

Evidence

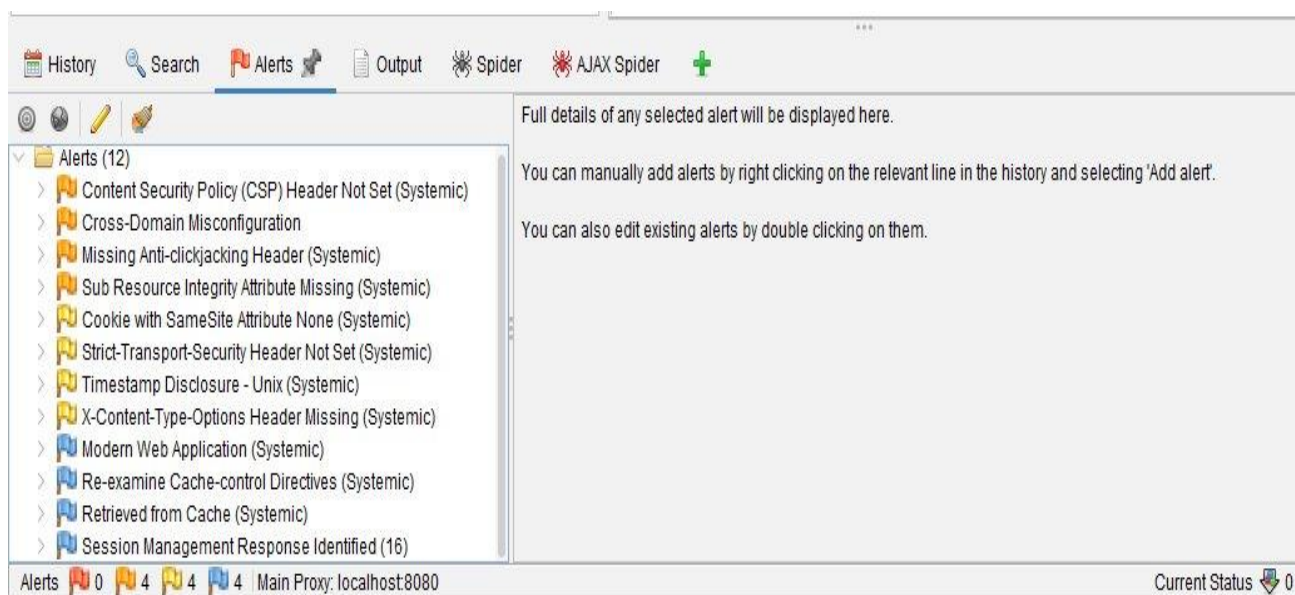


Figure 5 — ZAP scan showing CSP header not set (Zap_Scan_Report_1.png)

09 Conclusion & Remediation Roadmap

The security assessment of hexacoreclasses.in revealed no critical or high-severity vulnerabilities, indicating a reasonably maintained web application infrastructure. The platform's use of Cloudflare CDN provides meaningful baseline protection against volumetric attacks and basic filtering. However, four security misconfigurations were identified — three rated Medium and one rated Low — that represent genuine risk if left unaddressed.

Remediation Priority Roadmap

#	Severity	Action Required	Effort	Timeline
1	MEDIUM	Implement all missing HTTP security headers (HSTS, X-Frame, X-Content-Type)	Low	Immediate
2	MEDIUM	Define and enforce a strict Content Security Policy (CSP) header	Medium	1–2 Weeks
3	MEDIUM	Add X-Frame-Options: DENY to eliminate clickjacking risk	Low	Immediate
4	LOW	Restrict port 8080 via firewall; audit all exposed network services	Low	1 Month

Strategic Recommendations

- ▶ Adopt a Secure-by-Default server configuration template for all HTTP response headers
- ▶ Integrate automated security header checks into the CI/CD deployment pipeline
- ▶ Conduct quarterly vulnerability scans using OWASP ZAP or equivalent tooling
- ▶ Schedule annual full-scope penetration tests to assess evolving risk exposure
- ▶ Provide developer training on OWASP Top 10 and secure HTTP response configuration

Prasad Sarkate

Penetration Tester | Security Analyst

Future Interns | 22/04/2026

Assessment Summary

Total Findings: 4 (Medium: 3, Low: 1)

Critical / High: 0 — No immediate breach risk

Status: Awaiting Client Remediation

— End of Report — This document is classified CONFIDENTIAL —